

MODULE 04 · DOMAIN 1 - DETECTION

Six questions, six services

Config, Security Hub CSPM, Inspector and Macie – and how to tell which one a question is really asking about.

DOMAIN 1 of 6 EXAM WEIGHT 16% MODULE 4 of 39

Each service answers **one question**. The scenario always tells you which question it is asking.

The six questions

THE QUESTION THE SCENARIO IS ASKING	THE SERVICE
Is this configured as we said, and what did it look like on Tuesday?	AWS Config
Is something behaving maliciously right now?	GuardDuty
Is this software exploitable? Which CVE?	Amazon Inspector
Is there sensitive data where it should not be?	Amazon Macie
Are we meeting the standard we claim to meet?	Security Hub CSPM
Who outside this account can reach this resource?	IAM Access Analyzer

ON THE EXAM

Learn this table properly and you will answer questions faster than you can read all four options.

AWS Config: nothing works until the recorder is on

- ◆ The **configuration recorder** is the prerequisite for everything. No recorder means no rules, no history, no evaluations.
- ◆ It is **per account and per Region**. Enabling it in one Region says nothing about another.
- ◆ It captures **configuration items**, so you can ask what a security group looked like on any past date.
- ◆ Recording can be **continuous or daily**. Daily cuts cost when you need a position, not every change.
- ◆ **Security Hub CSPM controls backed by Config rules cannot evaluate without it.**

ON THE EXAM

'Config is not enabled in that Region' is the root cause of a whole family of scenarios.

Config rules, packs, aggregators and remediation

- ◆ **Managed rules** for common checks. **Custom rules** backed by Lambda or Guard for your own policy.
- ◆ **Conformance packs** bundle rules and remediations into one artefact, deployable org-wide.
- ◆ **Aggregators** collect compliance data across accounts and Regions. Config's centralisation mechanism.
- ◆ **Remediation** runs an SSM Automation document. Automatic makes Config corrective, not just detective.
- ◆ Remediation is **reactive**. There is always a window where the resource is wrong.

ON THE EXAM

Config detects then corrects. An SCP prevents. Read which one the question wants.

Security Hub is two products now

- ◆ **Security Hub CSPM** is what you knew as Security Hub. Standards, controls, security score, ASFF findings, aggregation.
- ◆ **Security Hub**, the December 2025 release, **correlates** across GuardDuty, Inspector, Macie and Security Hub CSPM into risk analytics.
- ◆ Different APIs. **EnableSecurityHub** for CSPM, **EnableSecurityHubV2** for the new one.
- ◆ **The SCS-C03 exam guide says 'AWS Security Hub' throughout.** Answer with CSPM behaviour – standards, controls, scores.
- ◆ Both are **Regional**. Cross-Region aggregation consolidates into one aggregation Region.

ON THE EXAM

Dated, and worth stating plainly: the console will not match your study notes. The exam is testing CSPM behaviour.

Standards, controls and the noise problem

- ◆ **FSBP** is the AWS baseline. **CIS**, **PCI DSS** and **NIST SP 800-53** are the external frameworks.
- ◆ CIS v5.0 arrived October 2025 with 40 controls. There is also an AWS Resource Tagging standard.
- ◆ **Consolidated control findings**: one finding per control, even when several standards share it.
- ◆ On by default only if you enabled CSPM **on or after 23 February 2023**. Older accounts have it off.
- ◆ It **cannot** be set by central configuration. Members inherit it from the administrator.

ON THE EXAM

Four standards without consolidation multiplies your findings by four.

Amazon Inspector: what it actually scans

- ◆ **EC2** – OS and language CVEs, plus network reachability. **Hybrid mode by default**: SSM agent, or EBS snapshots.
- ◆ **ECR images** – enhanced scanning. **Lambda** – packages, layers, optionally the code.
- ◆ Also **CIS Benchmark assessments** for the EC2 OS, and **SBOM export**.
- ◆ **Inspector identifies. It never remediates.** The fix is Patch Manager, the pipeline, or a developer.
- ◆ Network reachability, ECR and Lambda scanning need **no agent**.

ON THE EXAM

Inspector finds the CVE. GuardDuty sees it exploited. Patch Manager fixes it.

ECR basic scanning, or Inspector enhanced scanning?

ECR BASIC SCANNING

A gate on push

- Built into ECR, not Inspector
- Scans on push only
- OS packages only
- Never rescans for new CVEs

INSPECTOR ENHANCED SCANNING

A living inventory

- OS and language packages
- Auto-rescan as new CVEs land
- Risk score, routed to Security Hub
- Converts the whole registry

THE TIEBREAKER

'Disclosed after the image was built' is the deciding phrase. Basic scanning never finds it.

Amazon Macie: two ways to look at S3

- ◆ **Automated sensitive data discovery** – continuous, samples all buckets, cheap, gives you a map.
- ◆ **Sensitive data discovery jobs** – you scope them, they analyse fully, they cost more.
- ◆ **Managed data identifiers** for common types. **Custom** ones are your own regex.
- ◆ **Allow lists** suppress known-benign matches, like your own test fixtures.
- ◆ **Macie reads S3 and nothing else.** Not EBS, RDS, DynamoDB or EFS.

ON THE EXAM

Breadth is automated discovery. Depth on one bucket is a job.

The pattern that repeats across all of them

- ◆ **Delegated administrator** for GuardDuty, Security Hub CSPM, Inspector, Macie, Detective and Access Analyzer. Run security from the security account.
- ◆ **Auto-enable** so accounts joining the organisation are covered without anyone doing anything.
- ◆ **Config uses an aggregator** for the multi-account view, which is a different mechanism with a similar purpose.
- ◆ Security Hub CSPM **central configuration** pushes standards and controls across accounts and Regions in one action.
- ◆ All of these are **Regional**. Every one of these settings is per Region unless you aggregate.

ON THE EXAM

When a scenario says 'operated from the security account' and 'future accounts too', you are being asked for delegated admin plus auto-enable.

A university enables Security Hub CSPM with the FSBP standard across 60 accounts using central configuration, with a delegated administrator in the security account and cross-Region aggregation into eu-west-1.

After two weeks the security score for 22 accounts sits at 100%, which the team finds implausible. Investigating, they see that in those accounts most controls show a status of No data rather than Passed or Failed. GuardDuty findings from the same accounts are arriving normally.

What is the MOST likely cause?

- ☐ A Consolidated control findings is disabled in those member accounts
- ☐ B The AWS Config configuration recorder is not enabled in those accounts and Regions
- ☐ C Cross-Region aggregation does not carry control statuses, only findings
- ☐ D The FSBP standard was enabled but its controls were not individually activated

◆ PAUSE AND DECIDE

What is the MOST likely cause?

- A

 Consolidated control findings is disabled
That changes how many findings you get per control, not whether a control evaluates. It would produce more findings, never No data.
- B

 The Config recorder is not enabled in those accounts and Regions
Correct. Controls backed by Config rules cannot evaluate without the recorder, so they report No data – and No data does not count against the score.
- C

 Aggregation carries findings but not control statuses
Invented. Cross-Region aggregation carries findings, control statuses and security scores. Worth recognising a fabricated limitation.
- D

 Controls were not individually activated
Enabling a standard enables its controls by default. And a deactivated control is reported as disabled, which again is not No data.

THE SIGNAL

A 100% score is the tell. No data does not count against you, so missing evaluation looks exactly like perfect compliance.

A payments company must ensure every new EBS volume is encrypted. Engineers occasionally create unencrypted volumes through the console. The security team wants unencrypted volumes reported and the underlying misconfiguration fixed automatically, with an audit record showing when each one was corrected.

A proposal to deny `ec2:CreateVolume` without encryption via an SCP was rejected by the platform team, who say it would break a legacy migration tool that runs for another six months.

What should the security team implement?

- ☐ A An AWS Config rule for encrypted volumes with an automatic SSM Automation remediation
- ☐ B An Amazon Inspector scan configured to detect unencrypted EBS volumes
- ☐ C A GuardDuty Malware Protection for EC2 plan scoped to EBS volumes
- ☐ D Amazon Macie automated sensitive data discovery across the EBS volumes

◆ PAUSE AND DECIDE

What should the security team implement?

- A

 Config rule with automatic SSM Automation remediation
Correct. Encryption state is configuration, which is Config's question. Automatic remediation fixes it, and Config records the compliance timeline as the audit trail.
- B

 Inspector scan for unencrypted volumes
Inspector answers 'is this exploitable', not 'is this configured correctly'. It scans for CVEs and network exposure, and it never remediates anything.
- C

 GuardDuty Malware Protection for EC2
Scans EBS volumes for malware when behaviour looks suspicious. Malware is a different question from encryption, and again there is no remediation.
- D

 Macie across EBS volumes
Two errors. Macie reads S3 only, and 'what is in the data' is not the question. The question is about the volume's configuration.

THE SIGNAL

The rejected SCP is not scenery. It rules out prevention and tells you the answer must be detect-then-correct.

A software company pushes container images to Amazon ECR from its build pipeline. ECR basic scanning is enabled and the pipeline blocks any push where a HIGH or CRITICAL finding is returned.

A critical vulnerability is disclosed in a widely used library. Several images already in ECR contain the affected version and are running in production, but ECR reports no findings against them. Those images were pushed and scanned before the disclosure.

What should the company implement?

- ☐ A Configure ECR basic scanning to rescan images on a weekly schedule
- ☐ B Enable GuardDuty Runtime Monitoring to detect exploitation of the library
- ☐ C Activate Amazon Inspector ECR scanning, which converts the registry to enhanced scanning
- ☐ D Rebuild and re-push every image in the registry to trigger fresh basic scans

◆ PAUSE AND DECIDE

What should the company implement?

- A

 Schedule weekly rescans in ECR basic scanning
Basic scanning has no rescan capability to schedule. It scans on push and that is the whole feature. A fabricated option.
- B

 GuardDuty Runtime Monitoring
Answers a different question. It would tell you someone is exploiting the library, not that the library is vulnerable. You want to know before, not during.
- C

 Activate Inspector ECR scanning
Correct. Enhanced scanning automatically rescans existing images as new CVEs are published, which is precisely the gap. It also covers language packages, not just OS.
- D

 Rebuild and re-push everything
It would surface today's CVE and solve nothing structurally. The identical gap reopens with the next disclosure, and it is enormous manual effort.

THE SIGNAL

'Pushed and scanned before the disclosure' names the gap exactly. A scan is a moment; a vulnerability inventory is continuous.

A retailer has around 400 S3 buckets accumulated over a decade. Nobody can say which contain personal data. Regulators have asked for evidence of ongoing awareness of where personal data resides, and the security team must report quarterly.

A full content scan of all 400 buckets was costed and rejected as far too expensive. The team wants continuous coverage of the whole estate, with the ability to run a deep analysis on any bucket that looks interesting.

What should the retailer implement?

- ☐ A A scheduled Macie sensitive data discovery job across all 400 buckets each quarter
- ☐ B AWS Config rules checking bucket encryption and public access settings
- ☐ C S3 Inventory reports analysed with Athena to classify object contents
- ☐ D Macie automated sensitive data discovery, with targeted discovery jobs on buckets it flags

◆ PAUSE AND DECIDE

What should the retailer implement?

- A

 Quarterly discovery job across all 400 buckets
This is the full content scan that was already costed and rejected. Putting it on a schedule makes it recurring rather than cheaper.
- B

 Config rules for encryption and public access
Answers whether buckets are configured correctly. An encrypted, private bucket full of unexpected personal data passes every one of these checks.
- C

 S3 Inventory with Athena
Inventory lists objects and their metadata – key, size, encryption status. It never opens an object, so it cannot classify contents.
- D

 Automated discovery, with targeted jobs on what it flags
Correct. Sampling gives continuous estate-wide awareness cheaply, and jobs supply depth exactly where it is justified.

THE SIGNAL

Two requirements pulling opposite ways – broad and cheap, deep where needed – is Macie's two modes described in the question's own words.

Five things to carry forward

- ◆ **No Config recorder means No data, and No data does not lower your score.** Missing checks look like perfect compliance.
- ◆ **Config detects then corrects. An SCP prevents.** Read whether the change must be impossible or merely fixed.
- ◆ **Basic ECR scanning never rescans.** A CVE disclosed after the push will never be found.
- ◆ **Macie has two modes.** Sampling for breadth, jobs for depth. And it reads S3 only.
- ◆ **Configuration is not content.** A perfectly configured bucket can hold data that should not be there.

ON THE EXAM

Next: Security Lake, OCSF, Athena and Managed Grafana – what to do once every one of these services is producing findings.